

SECURITY ASSESSMENT REPORT (SAR)

AwardWorks Grants Management Platform

Tailspin Civic Systems, Inc. | FedRAMP Moderate | NIST SP 800-53A Rev. 5

Assessment Period: 2026-01-12 to 2026-02-27 | Report Date: 2026-03-06

Fictional organization. Created for portfolio demonstration purposes.

1. Executive Summary

An independent security control assessment of the AwardWorks Grants Management Platform was performed against the FedRAMP Moderate baseline using the assessment methods and procedures defined in NIST SP 800-53A Rev. 5. The assessment evaluated 33 sampled controls across 16 control families using examination, interview, and technical testing.

Of the controls assessed, 24 were determined Satisfied and 9 were determined Other Than Satisfied. One of the 24 (SC-15) is a Not Applicable determination the team examined and accepted. Eight findings were identified: two rated High risk, four Moderate, and two Low. No finding indicated an active compromise, and no control deficiency was assessed as rendering the system fundamentally unsuitable for operation.

The two High-risk findings share a common theme: security work that is well defined on paper but lacks an enforcement mechanism to guarantee execution. FIND-001 concerns vulnerability remediation SLAs that exist without automated escalation, and FIND-002 concerns a least-privilege requirement that was not enforced as the system scaled. Both are addressable through automation and control gating rather than architectural change.

Management concurred with all eight findings and provided remediation plans with committed completion dates, each tracked to a corresponding POA&M item. Based on the assessed control posture and the credibility of the submitted remediation plans, the assessment team recommends that the Authorizing Official consider granting an Authority to Operate conditioned on completion of the two High-risk POA&M items within their committed timelines.

2. Assessment Scope and Methodology

The assessment covered all components within the AwardWorks authorization boundary as documented in the System Security Plan v2.0, including the web application tier, API tier, database, document storage, identity integration layer, and logging pipeline. Controls fully inherited from AWS GovCloud under its FedRAMP High P-ATO were verified as inheritable but not independently reassessed.

2.1 Assessment Methods

Method	Description
Examine	Review of policies, procedures, plans, architecture diagrams, configuration exports, scan results, ticket records, and prior assessment artifacts
Interview	Structured interviews with the ISSO, System Owner, Security Operations Lead, Incident Response Lead, Director of Platform Engineering, Cloud Infrastructure Lead, and two on-call engineers
Test	Technical validation including authenticated configuration scanning, sampling of 12 production hosts, privileged-action logging tests, access control validation, and encryption verification

2.2 Risk Rating Methodology

Each finding was assigned a risk rating derived from the likelihood of exploitation or occurrence and the magnitude of impact to confidentiality, integrity, or availability of the system and the federal information it processes, consistent with NIST SP 800-30 Rev. 1.

Rating	Definition and Expected Response
High	Deficiency presents a significant risk to the system or federal data. Remediation required within 30 days of discovery; may condition the authorization decision.
Moderate	Deficiency presents a meaningful risk that is limited in scope, likelihood, or impact. Remediation required within 90 days of discovery.
Low	Deficiency presents limited risk, or primarily affects the ability to evidence a control rather than its underlying operation. Remediation required within 180 days of discovery.

3. Summary of Results

Assessment Outcome	Count	% of Sampled	Notes
Satisfied	24	72.7%	Control operating as designed and documented; includes the SC-15 Not Applicable determination
Other Than Satisfied	9	27.3%	Deficiency identified; POA&M item generated
Total Sampled	33	100%	33 controls across 16 families

3.1 Findings by Risk Rating

Risk Rating	Count	Finding IDs
High	2	FIND-001, FIND-002
Moderate	4	FIND-003, FIND-004, FIND-005, FIND-006
Low	2	FIND-007, FIND-008

3.2 Findings Index

Finding ID	Title	Risk	POA&M ID
FIND-001	High-Severity Vulnerabilities Exceeded Required Remediation Timeline	High	V-001
FIND-002	Shared Service Account Prevents Attribution of Privileged Database Actions	High	V-008
FIND-003	Audit Trail Gap for Privileged Functions on Legacy Reporting Subsystem	Moderate	V-003
FIND-004	Annual System Recovery Exercise Not Performed	Moderate	V-004

FIND-005	Configuration Drift from Approved Hardening Baseline	Moderate	V-002
FIND-006	Incident Notification Timeline Not Validated Through Exercise	Moderate	V-006
FIND-007	Inconsistent Evidence of Weekly Audit Log Review	Low	V-005
FIND-008	Late Submission of Continuous Monitoring Deliverables	Low	V-007

4. Detailed Findings

Each finding below follows the standard audit structure of condition, criteria, cause, and effect, followed by the evidence reviewed, the assessment team's recommendation, and management's formal response.

FIND-001 — High-Severity Vulnerabilities Exceeded Required Remediation Timeline

Risk Rating	High	Affected Control(s)	RA-5, SI-2
Source	Technical Test / Scan Review	POA&M ID	V-001

Condition. Review of six months of authenticated vulnerability scan results identified 14 High-severity findings that remained open beyond 30 days from discovery, with the longest open 94 days at the time of assessment.

Criteria. FedRAMP requires that High-severity vulnerabilities in a Moderate-impact system be remediated within 30 days of discovery. NIST SP 800-53 Rev. 5 control RA-5 requires remediation of legitimate vulnerabilities within organization-defined response times, and SI-2 requires timely flaw remediation.

Cause. The vulnerability management pipeline generates findings and assigns tickets but contains no automated escalation when a remediation SLA is approaching or has been breached. Remediation prioritization was handled informally within sprint planning, where security findings competed with feature work without a governing escalation mechanism.

Effect. Known, exploitable vulnerabilities remained present in the production environment for extended periods, materially increasing the likelihood of successful compromise of a system processing CUI and applicant PII. Sustained non-compliance with FedRAMP remediation timelines also places the system's continued authorization at risk.

Evidence Reviewed. Monthly scan results (Sep 2025 – Feb 2026); vulnerability ticket export with creation and closure timestamps; interview with the Director of Platform Engineering; review of sprint planning records.

Recommendation. Implement automated SLA tracking within the vulnerability management pipeline that escalates to engineering leadership at 15 days and to the ISSO and System Owner at 25 days for High-severity findings. Remediate all currently open High findings, and institute a weekly SLA burn-down review with documented accountability.

Management Response. Concur. Automated SLA escalation will be implemented by 2026-06-22 and all currently open High findings remediated by 2026-05-18, with validation via a clean scan cycle by 2026-06-25. Tracked as POA&M V-001. — Director of Platform Engineering

FIND-002 — Shared Service Account Prevents Attribution of Privileged Database Actions

Risk Rating	High	Affected Control(s)	AC-2
-------------	------	---------------------	------

Source	Internal Self-Assessment / Technical Test	POA&M ID	V-008
--------	---	----------	-------

Condition. A single shared service account holding elevated database privileges is used by four distinct batch processing jobs. Database audit logs therefore attribute all actions taken by these jobs to one identity, and the account's privileges exceed what any individual job requires.

Criteria. AC-2 requires that the organization manage system accounts, including service accounts, in a manner that supports individual accountability. The excess privilege held by the shared account also conflicts with least privilege (AC-6), which was outside the 33-control sample and is noted for the AO rather than rated separately.

Cause. The shared account was created during initial platform development to simplify batch job configuration and was never decomposed as the number of jobs grew. No control gate existed to prevent additional jobs from reusing the existing credential.

Effect. In the event of unauthorized or erroneous database activity, investigators cannot determine which process — or which human operator invoking it — performed the action, materially impairing incident response and forensic capability. The excessive privilege also increases the blast radius of a single credential compromise.

Evidence Reviewed. Database role and grant export; batch job configuration files; sample of database audit log entries; interview with the Director of Platform Engineering.

Recommendation. Inventory the minimum privileges required by each batch job, create a dedicated IAM database role per job scoped to those privileges, migrate each job, and then disable the shared account. Validate that database audit logs correctly attribute actions to the individual job identities after migration.

Management Response. Concur. Privilege inventory will be completed by 2026-05-26, scoped roles created and jobs migrated by 2026-07-27, and the shared account disabled with log validation by 2026-08-27. Tracked as POA&M V-008. — Director of Platform Engineering

FIND-003 — Audit Trail Gap for Privileged Functions on Legacy Reporting Subsystem

Risk Rating	Moderate	Affected Control(s)	AC-6(9)
Source	Technical Test	POA&M ID	V-003

Condition. Privileged function execution on the legacy reporting subsystem is not forwarded to the centralized SIEM. Testing confirmed that administrative actions performed on this component produced local logs only, with no corresponding SIEM record.

Criteria. AC-6(9) requires logging the execution of privileged functions. The approved auditable events list (AU-2) already names privilege escalation and administrative actions, and AU-2 was assessed as Satisfied; the gap is that one component's events never reach the SIEM.

Cause. The legacy reporting subsystem predates the current logging architecture and was not included in the log-forwarding agent rollout. No reconciliation was performed between the approved auditable events list and actual SIEM ingestion coverage.

Effect. Administrative actions on a component with access to award and disbursement reporting data are not centrally monitored, alerted on, or retained per policy. Malicious or erroneous privileged activity on this subsystem would likely go undetected.

Evidence Reviewed. SIEM source inventory; approved auditable events list; test execution of a privileged action with subsequent SIEM query returning no results; system architecture diagram.

Recommendation. Deploy the log-forwarding agent to the legacy reporting subsystem and validate coverage against the full approved auditable events list. Establish a recurring reconciliation between the auditable events list and actual SIEM source coverage to prevent recurrence on future components.

Management Response. Concur. Agent deployment by 2026-04-20, event coverage validation by 2026-05-05, and SIEM alerting confirmation by 2026-05-18. A quarterly source-coverage reconciliation will be added to the ConMon calendar. Tracked as POA&M V-003. — Security Operations Lead

FIND-004 — Annual System Recovery Exercise Not Performed

Risk Rating	Moderate	Affected Control(s)	CP-10
Source	Interview / Documentation Review	POA&M ID	V-004

Condition. A full-system recovery and reconstitution exercise has not been conducted within the required annual period. Component-level backup restoration has been tested successfully, but no end-to-end exercise has validated the documented recovery time and recovery point objectives.

Criteria. CP-10 requires the organization to provide for recovery and reconstitution of the system to a known state after a disruption, and contingency plan testing (CP-4) is required at least annually for Moderate-impact systems.

Cause. Recovery testing was descoped from the prior year's schedule due to a concurrent platform migration, and was not rescheduled or tracked to completion.

Effect. The organization's actual recovery capability is unverified. Documented RTO and RPO values may not be achievable in practice, which would extend an outage of a system supporting statutorily deadlines grant cycles and could result in missed federal disbursement obligations.

Evidence Reviewed. Contingency Plan (v1.4); prior-year test records; interview with the Director of Infrastructure; backup restoration test logs for the database tier.

Recommendation. Conduct a full-system recovery exercise in an isolated environment with defined success criteria, measure actual RTO and RPO against documented objectives, and update the Contingency Plan based on exercise findings. Add contingency plan testing to the continuous monitoring calendar as a non-descopable annual activity.

Management Response. Concur. Exercise scenario and success criteria by 2026-05-26; exercise execution by 2026-07-20; Contingency Plan update and after-action report by 2026-07-27. Tracked as POA&M V-004. — Director of Infrastructure

FIND-005 — Configuration Drift from Approved Hardening Baseline

Risk Rating	Moderate	Affected Control(s)	CM-6
Source	Technical Test (Sampling)	POA&M ID	V-002

Condition. Sampling of 12 production application servers identified three hosts with settings deviating from the approved CIS Level 1 hardening baseline, including a permissive SSH configuration permitting password authentication and a disabled host-based audit daemon.

Criteria. CM-6 requires that the organization establish, document, and enforce configuration settings that reflect the most restrictive mode consistent with operational requirements, and monitor for and correct unauthorized changes.

Cause. AWS Config drift detection is deployed in monitoring-only mode without automatic remediation, and no pre-deployment gate verifies baseline compliance. Manual troubleshooting changes made during an earlier incident were not reverted.

Effect. Hosts operating outside the approved baseline present a larger attack surface than the assessed and authorized configuration. The permissive SSH setting specifically weakens authentication controls on production systems processing CUI.

Evidence Reviewed. Configuration scan output for 12 sampled hosts; approved CIS Level 1 baseline document; AWS Config rule configuration; change records from the referenced incident.

Recommendation. Re-image the affected hosts from the approved AMI, enable automatic remediation for baseline configuration rules in AWS Config, and add a pre-deployment drift verification gate to the CI/CD pipeline so non-compliant configurations cannot reach production.

Management Response. Concur. Affected hosts re-imaged by 2026-04-17; Config auto-remediation enabled by 2026-05-18; pre-deploy drift gate implemented by 2026-05-27. Tracked as POA&M V-002. — Cloud Infrastructure Lead

FIND-006 — Incident Notification Timeline Not Validated Through Exercise

Risk Rating	Moderate	Affected Control(s)	IR-6
Source	Interview	POA&M ID	V-006

Condition. The Incident Response Plan documents the required one-hour notification to CISA and the sponsoring agency ISSO, but this timeline has never been validated through a tabletop or live exercise. Interviewed personnel expressed uncertainty about the after-hours escalation path to Legal and Communications.

Criteria. IR-6 requires incident reporting within organization- and FedRAMP-defined timeframes, and FedRAMP requires notification to CISA and the agency within one hour of incident determination. Incident handling itself (IR-4) was assessed as Satisfied; the deficiency is limited to the external reporting workflow.

Cause. Incident response exercises conducted to date focused on technical containment and eradication scenarios and did not include the external notification workflow or non-technical stakeholders.

Effect. The organization cannot demonstrate its ability to meet a mandatory one-hour federal notification requirement. A delay in notification during an actual incident would constitute a compliance failure and could delay the agency's own response and downstream notifications.

Evidence Reviewed. Incident Response Plan (v2.0); prior tabletop exercise after-action reports; interviews with the Incident Response Lead and two on-call engineers; on-call escalation roster.

Recommendation. Conduct a tabletop exercise specifically designed to test the external notification workflow, including Legal and Communications participation and an after-hours scenario. Measure actual elapsed time to notification, and update the IR Plan and contact roster based on results.

Management Response. Concur. Tabletop scenario developed by 2026-05-08, exercise executed with Legal and Communications by 2026-06-02, and IR Plan and roster updated by 2026-06-22. Tracked as POA&M V-006. — Incident Response Lead

FIND-007 — Inconsistent Evidence of Weekly Audit Log Review

Risk Rating	Low	Affected Control(s)	AU-6
-------------	-----	---------------------	------

Source	Documentation Review	POA&M ID	V-005
--------	----------------------	----------	-------

Condition. The documented weekly audit log review procedure could not be evidenced for a two-month period. Interviewed personnel stated that reviews occurred, but no artifact recorded the reviewer, date, scope, or outcome.

Criteria. AU-6 requires review and analysis of audit records at an organization-defined frequency for indications of inappropriate or unusual activity, and reporting of findings. Assessment requires evidence that the activity occurred.

Cause. The review process relied on an informal practice with no artifact-generating workflow. Absence of a record made the control unassessable regardless of whether the underlying activity was performed.

Effect. The organization cannot demonstrate that audit records were reviewed during the affected period. Any anomalous activity present in logs during that window may have gone unexamined, and the control cannot be assessed as operating effectively.

Evidence Reviewed. SIEM review documentation for the trailing six months; interview with the Security Operations Lead; SIEM saved-search and dashboard access logs.

Recommendation. Implement a ticketed workflow that generates an auditable record for each weekly review capturing reviewer, date, scope, findings, and any escalations. Complete four consecutive evidenced review cycles before requesting closure.

Management Response. Concur. Ticketed review workflow implemented by 2026-04-10, with four consecutive evidenced cycles completed by 2026-04-27. Tracked as POA&M V-005. — Security Operations Lead

FIND-008 — Late Submission of Continuous Monitoring Deliverables

Risk Rating	Low	Affected Control(s)	CA-7
Source	FedRAMP ConMon Review	POA&M ID	V-007

Condition. Monthly continuous monitoring deliverables were submitted after the required deadline in two of the last six reporting cycles, by four and seven business days respectively.

Criteria. CA-7 requires a continuous monitoring strategy including reporting of the security posture at an organization-defined frequency. FedRAMP requires monthly ConMon deliverables by a defined submission date.

Cause. Deliverable assembly is a manual process performed by a single individual with no designated backup. Both late submissions coincided with that individual's planned absence.

Effect. Late submissions reduce the Authorizing Official's visibility into current system risk posture and, if sustained, may be treated as a condition affecting the system's continued authorization.

Evidence Reviewed. ConMon submission records for the trailing six months; deliverable assembly procedure documentation; interview with the ISSO.

Recommendation. Automate assembly of the ConMon deliverable package, establish an internal deadline five business days ahead of the external due date, and designate and train a documented backup submitter.

Management Response. Concur. Automated package generation by 2026-05-08; internal deadline and backup owner established by 2026-05-18; two consecutive on-time cycles demonstrated by 2026-05-27. Tracked as POA&M V-007. — ISSO

5. Recommended Authorization Decision

The assessment team recommends that the Authorizing Official grant an Authority to Operate for the AwardWorks Grants Management Platform, conditioned on the following:

- Completion of POA&M items V-001 and V-008, corresponding to the two High-risk findings, within their committed remediation dates, with evidence validated by the ISSO.
- Submission of monthly continuous monitoring deliverables demonstrating measurable progress against all open POA&M items.
- Notification to the Authorizing Official if any High-risk POA&M item milestone date is missed, accompanied by a revised plan or a formal deviation request.

This recommendation reflects the assessment team's determination that the identified deficiencies are process and enforcement gaps rather than architectural weaknesses, that the underlying security architecture is sound, and that management has demonstrated both accurate self-identification of issues and credible remediation planning.

6. Assessment Team and Attestation

Role	Assigned
Lead Assessor	Independent Third-Party Assessment Organization (A2LA-accredited)
Technical Assessor	3PAO technical testing team
Organizational Point of Contact	Chris Morrissey, ISSO, Tailspin Civic Systems
Assessment Period	2026-01-12 through 2026-02-27
Report Date	2026-03-06

This report presents the results of an independent assessment conducted in accordance with NIST SP 800-53A Rev. 5 and applicable FedRAMP assessment requirements. Findings reflect the state of the system during the assessment period and do not constitute a guarantee of security or a warranty of future control effectiveness.